POLITICA DE SEGREGAÇÃO DE FUNÇÕES DE TI

Índice

1. Objetivo 3
2. Alcance 3
3. Definições e Abreviaturas 3
4. Papéis e Responsabilidades 3
5. Referências 4
6. Regras para Segregação de Funções 4
7. Sanções e Penalidades 5
8. Controle de Revisões 5

1. Objetivo

Estabelecer regras e padrões para o processo de Segregação de Funções da SMILES, visando assegurar a implementação da segregação de papéis e responsabilidades, bem como assegurar a manutenção da segregação apropriada durante os períodos em que o pessoal regular não está disponível.

2. Alcance

Todos os colaboradores da SMILES, sejam funcionários ou fornecedores externos, que executem alguma atividade nos Processos relacionados neste documento.

3. Definições e Abreviaturas

Segregação de Funções: refere-se a práticas onde o conhecimento e/ou privilégios necessários para se completar um processo são quebrados e divididos entre múltiplos usuários de forma que apenas um seja capaz de executá-lo ou controla-lo sozinho.

Processo Crítico: equivale ao conjunto definido de passos para realizar uma tarefa crítica, ou aquelas que mais impactam os negócios e afetam os clientes.

Atividade Crítica: equivale a realizar uma tarefa ou a um trabalho na sua forma ativa fundamental para realizar uma tarefa.

RH: acrônimo para Recursos Humanos.

TI: acrônimo para Tecnologia da Informação.

4. Papéis e Responsabilidades

Controles Internos: responsável por elaborar e disseminar políticas corporativas que auxiliarão os colaboradores da SMILES na compreensão e entendimento sobre as regras e padrões para a Segregação de Funções.

Segurança da Informação: responsável por relacionar, validar e atualizar a Lista de Processos Críticos periodicamente; deve garantir a publicação das atualizações de Segregação de Funções no Confluence; e solicitar correções, quando identificado, em Funções Críticas.

Dono do Processo Crítico: responsável por relacionar, validar e atualizar as atividades dos Processos Críticos definidos pela equipe de Segurança da Informação, bem como as funções e segregação de deveres para cada Atividade Crítica; deve garantir a correção de desvios em Funções Críticas.

Recursos Humanos: responsável por manter a área de TI (Segurança da Informação) ciente das contratações de novos colaboradores, transferências entre áreas com alteração de função e ausências (licenças, férias) permitindo alocação mais adequada das atividades de aprovação para Processos Críticos.

5. Referências

Processos SMILES

Gestão da Segurança de Processos

Padrões e Melhores Práticas de Mercado

CobiT® v4.1 (Control Objectives for Information and related Technology)

ISO/IEC 27001 (Information Security Management Systems - Requirements)

ISO/IEC 27002 (Code of Practice for Information Security Management)

6. Regras para Segregação de Funções

- Todos os Processos de TI que suportam os processos de negócios devem estar relacionadas no documento “Relação de Processos Críticos”.
- Todos os Processos Críticos de TI devem identificar o responsável capaz de responder processual e tecnicamente a respeito da ferramenta, identificado como “Dono do Processo”;
- Todas as atividades de cada Processo devem ser relacionadas e atualizadas pelo “Dono do Processo” no documento “Relação de Atividades Processo xxxx” de cada Processo;
- É de responsabilidade do “Dono do Processo” a classificação de todas as atividades executadas no Processo, usando como referência a lista abaixo:
    - **Inicia**: atividade de início de fluxo
    - **Executa**: atividade de execução de uma tarefa do processo
    - **Aprova**: atividade de aprovação (tomada de decisão) do processo
    - **Valida**: atividade de checagem/validação de uma tarefa anterior do processo
- Todo conflito de funções identificado pela equipe de Segurança da Informação deve solicitar a correção necessária para o “Dono do Processo”, conforme regras abaixo:

- **Quem Inicia Atividade "pode" Executar, Aprovar ou Validar.**
- **Quem Executa Atividade "não pode" Aprovar ou Validar.**
- **Quem Aprova Atividade "não pode" Executar ou Validar.**
- **Quem Valida Atividade "não pode" Executar ou Aprovar.**

7. Sanções e Penalidades

- O descumprimento desta norma será considerado falta grave, passível de aplicação de penalidades;
- Para funcionários SMILES, pode-se aplicar sanções administrativas, trabalhistas ou penais;
- Para fornecedores externos, pode-se solicitar a troca da equipe alocada na SMILES, ou ainda, aplicar penalidades à empresa prestadora de serviços, tais como: multas, cancelamento do contrato e/ou ações judiciais.

8. Controle de Revisões

Revisão	Data	Páginas afetadas	Descrição da Modificação
1.0	18/04/2017	Todas	Definição da Política de Segregação de Funções